

CYBERSECURITY

LAB 8

1. Introduction

Hacking attacks are not always associated with accessing your computer or data on the server. Increasing the importance of the Internet and the amount of transmitted data in the network has resulted in the development of attacks related to network communication, especially those belonging to the group of **Man in the Middle** attacks.

MitM is a group of attacks whose basic assumption is to eavesdrop communication between two devices in the network. As a result, the attacker gets access to the data transmitted during communication, can read it, modify it at will (altogether with a complete change of transmitted content, e.g. to transmit a fake website) and block it.

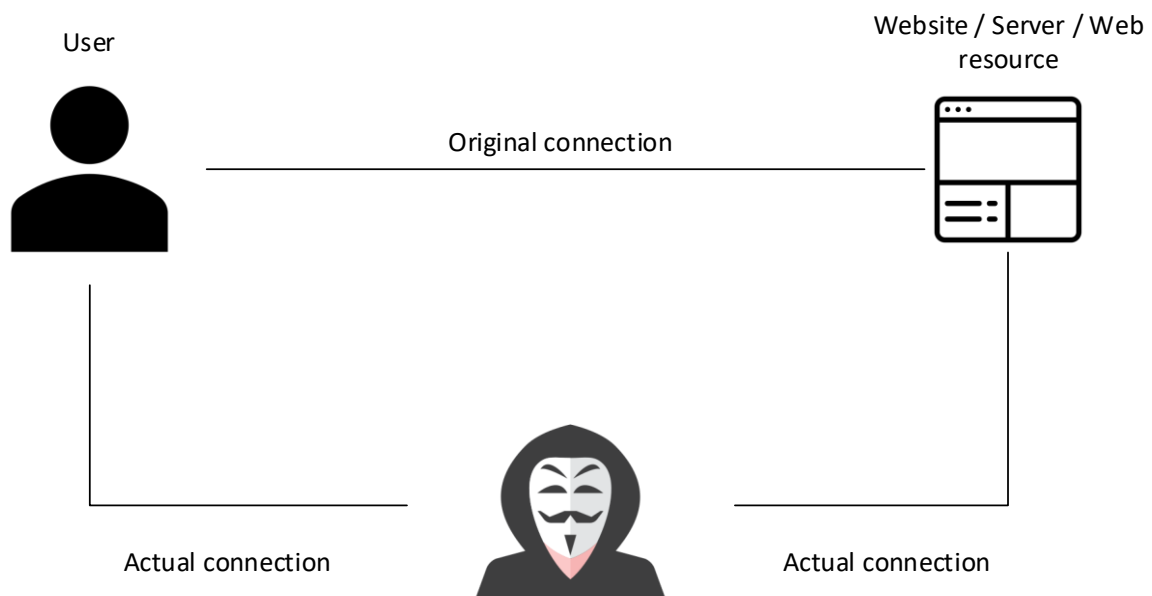


Figure 1 Man of the Middle attack idea

MitM attacks can be classified into several groups:

- **Wi-Fi eavesdropping** - a simple type of attack consisting of creating hotspots / access points of Wi-Fi networks impersonating known and safe networks (e.g. cafes, cinemas, public networks). Using this attack, the hacker has the ability to send any content to the network user (e.g. fake versions of known web services).
- **ARP poisoning** - attack utilizing lack of authentication during transmission using ARP protocol. By sending appropriate ARP message the attacker poisons ARP routing table by setting MAC address of any devices in attacked network with own IP address. As a result of a change in the array, all the victim's network packets are sent to the attacker, at the same time the attacker is treated as the original recipient of the message and its replies as correct answers to any sent one.

LAB 8

- **DNS spoofing** - DNS cache poisoning allows an attacker to force the victim to download harmful data by trying to connect to known network services. An attacker sends a fake message containing a domain name and IP address of e.g. malicious website. When a victim tries to connect to a website by providing a domain name, he is redirected to the attacker's website.
- **ICMP redirects** - using ICMP redirect packets, an attacker could instruct a router to forward packets destined for the victim through the attacker's own machine. The attacker can then monitor or modify the packets before resent to their destination.
- **Port stealing** - an attack executed in local networks involving a change of information stored in the network switch forwarding table. Once this is done, all network packets addressed to the original port are redirected to the port to which the attacker's machine is connected.
- **STP mangling** - in the network each router assumes itself as the root bridge by default. However, it is possible to send Bridge Protocol Data Units (BPDUs) to establish a new root bridge. In the lack of support for adequate protection, all network traffic from the victim's switch starts to be transmitted by the switch indicated as root by the attacker.

2. Required virtual machines

- Kali
- Metasploitable2

3. Prerequisites

Get familiar with the following elements:

- Routing tables
- DNS
- APR
- DNS/ARP cache
- MAC
- Ettercap
- Arpspoof
- Wireshark

4. Problems and questions

- I. What is the difference between active and passive MitM attacks?
- II. How to protect your network against ARP poisoning attacks?
- III. Why it is important to use DNSSEC to prevent DNS spoofing attacks?
- IV. What is monitor mode and how can you use it to eavesdrop network communication?

5. Tasks

In some cases, the router's security mechanisms and the stored data in the cache may interfere with the observation of the result of the correct execution of the attack. In such a case, it may be necessary to correctly execute the attack:

- Connecting a computer to a hotspot launched with a smartphone

LAB 8

- Changing settings of VMs network cards to Bridged Adapter. Open VirtualBox -> Select each of yours VMs -> Settings -> Network -> Attached to: Bridged Adapter

Please remember to restore the previous network adapter settings after completing the tasks!

The ARP table for your computer will be modified during the exercise. Remember to terminate the MitM attack after completing the exercises to reverse this process!!!

- I. In this task, the victim machine is the Ubuntu Server VM. In addition, we will be using the Metasploitable 2 VM as a web server machine.
- II. Open command line and locate **etter.dns** file in Kali VM
locate etter.dns
- III. Navigate to this path and open the file
- IV. Edit the file to spoof WUST domain name (add new line next to “microsoft.com ...”
pwr.edu.pl A {KALI_VM_IP_ADDRESS}
***.pwr.edu.pl A {KALI_VM_IP_ADDRESS}**
www.pwr.edu.pl PTR {KALI_VM_IP_ADDRESS}
- V. On Kali VM start Apache2
service apache2 start
- VI. Run Ettercap on Kali VM
sudo ettercap -G
- VII. Start sniffing
- VIII. Use **Scan for hosts** and after finish go to **Hosts List** from Hosts menu.
- IX. Add your router/gateway IP to Target 1 (usually it will be IP address with 1 in last octet) and victim IP (Ubuntu Server VM) to Target 2
- X. Start ARP Poisoning
Mitm menu -> ARP Poisoning -> Check Sniff remote connections
- XI. Go to Plugins menu and activate dns_spoof plugin
Plugins -> Manage plugins -> double click on dsn_spoof
- XII. Open WUST website in the browser on your computer and observe the results
- XIII. Stop last MitM attack, clear Target 1 and Target 2
- XIV. Add a victim machine (Ubuntu Server VM) to Target 1 and Metasploitable VM to Target 2

LAB 8

- XV. Start ARP Poisoning once again
- XVI. Connect to Metasploitable VM from web browser on victim machine
Open browser -> `http://{METASPLOITABLE_VM_IP_ADDRESS}/dvwa`
- XVII. Open **DVWA** and try to log in with any login and password. Observe the results in ettercap.
- XVIII. Open Wireshark on Kali VM, start capture traffic on eth network interface and try to generate some network traffic on Metasploitable VM from Victim VM (try to log in again, open other applications on web server, try to connect with ssh). Observe the results.